

Threat Analysis Report

รายงานวิเคราะห์

Deadlock Ransomware

12/05/2026

TLP:CLEAR





สารบัญ

สารบัญ.....	2
บทสรุปสำหรับผู้บริหาร.....	3
Threat Actor Profile	4
การวิเคราะห์เชิงเทคนิค.....	5
Technique Tactics and Procedures (MITRE ATT&CK).....	9
Indicator of Compromise (IOCs).....	10
แนวทางการเฝ้าระวัง ป้องกัน และรับมือ.....	11
อ้างอิง (References).....	12

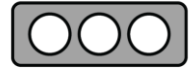


บทสรุปสำหรับผู้บริหาร

รายงานฉบับนี้วิเคราะห์ภัยคุกคามจาก Deadlock Ransomware มัลแวร์เรียกค่าไถ่สายพันธุ์ใหม่ที่เพิ่งพบกรณีการโจมตีหน่วยงานภาครัฐในประเทศไทย จากการตรวจสอบพบว่าผู้ไม่หวังดีสามารถเข้าถึงเครือข่ายภายในผ่านการใช้งานข้อมูลบัญชี VPN ของบริษัทคู่สัญญา (Outsource) ที่เกิดการรั่วไหล และสามารถเข้าควบคุมระบบ Hypervisor ได้อย่างสมบูรณ์โดยใช้รหัสผ่านระดับสูงสุด (Root) ของระบบ ESXi ที่บริษัท Outsource เป็นผู้ดูแล

ช่องว่างสำคัญด้านความมั่นคงปลอดภัยที่พบคือ การขาดการแบ่งแยกเครือข่ายที่เหมาะสม (Network Segmentation) โดยมีการตั้งค่า IP Management ของระบบ ESXi ให้อยู่ใน Subnet เดียวกับกลุ่ม Server ที่ใช้ในการให้บริการต่างๆ ส่งผลให้ผู้ไม่หวังดีสามารถเข้าถึงและดีพลอย (deploy) มัลแวร์ไปยังโครงสร้างพื้นฐานสำคัญของหน่วยงานได้อย่างง่ายดายหลังจากเข้าสู่เครือข่ายได้สำเร็จ

ในมิติของเทคนิคระดับสูง Deadlock มีความโดดเด่นในการผสมผสานนวัตกรรมเทคโนโลยี Web3 โดยใช้ Smart Contracts บนเครือข่ายบล็อกเชน Polygon เพื่อบริหารจัดการโครงสร้างพื้นฐานการควบคุมและสั่งการ (C2) แบบกระจายศูนย์ นอกจากนี้มีการรายงานว่าผู้ไม่หวังดีเคยใช้เทคนิค Bring Your Own Vulnerable Driver (BYOVD) ผ่านช่องโหว่ CVE-2024-51324 ใน Baidu Antivirus เพื่อยุติการทำงานของระบบตรวจจับและตอบโต้ภัยคุกคาม (EDR) ก่อนดำเนินการข่มขู่ในลักษณะ Double Extortion คือการเข้ารหัสข้อมูล (นามสกุล .dlock) ควบคู่ไปกับการขโมยข้อมูลสำคัญออกไปขายในตลาดมืด ซึ่งแสดงให้เห็นถึงขีดความสามารถทางเทคนิคที่สูงและการวางแผนโจมตีอย่างเป็นระบบเพื่อหลบเลี่ยงการตรวจจับในปัจจุบัน



Threat Actor Profile

ชื่อกลุ่ม: Deadlock Ransomware

ประวัติกลุ่ม:

Deadlock เป็น Ransomware family ที่ถูกค้นพบในช่วงเดือนกรกฎาคม 2568 และพบการโจมตีหน่วยงานในไทยล่าสุดเมื่อช่วงเดือนพฤษภาคม 2569 จุดเด่นของการดำเนินการมัลแวร์ตัวนี้คือไม่มีการเชื่อมโยงกับ Ransomware as a Service อื่น ๆ ที่รู้จักใด ๆ และไม่มี Data Leak Site (DLS) สาธารณะ ประกอบกับจำนวนเหยื่อที่รายงานได้น้อย ทำให้กลุ่มนี้ยังมีการเปิดเผยข้อมูลต่อสาธารณะค่อนข้างน้อย

เครื่องมือที่ใช้โจมตี:

- **Credential leaks:** ใช้งานข้อมูล Credential ที่รั่วไหลในการเข้าถึงระบบ VPN และโครงสร้างพื้นฐานอื่น ๆ ของเหยื่อ
- **BYOVD Driver Exploit:** ใช้ประโยชน์จากไดรเวอร์ที่มีช่องโหว่ (เช่น ไดรเวอร์ของ Baidu Antivirus CVE-2024-51324) เพื่อหยุดการทำงานของระบบรักษาความปลอดภัย
- **System Tools:** Command Shell (cmd.exe) และ PowerShell สำหรับการรันคำสั่งและ Payload หลัก
- **Infrastructure:** Polygon Blockchain Smart Contracts (ใช้เป็นช่องทางในการระบุพิกัด C2 แบบกระจายศูนย์)
- **Communication:** Session Messaging Application (แอปพลิเคชันส่งข้อความแบบเข้ารหัสและระบุตัวตนยาก ใช้ในการเจรจาค่าไถ่)

กลุ่มเป้าหมายหลัก:

- ระบบปฏิบัติการ Windows (Windows OS)
- ภาคส่วนที่มีโครงสร้างพื้นฐานสำคัญหรือธุรกิจที่มีความอ่อนไหวต่อระยะเวลาการหยุดทำงานของระบบ (Downtime) เช่น ภาคการผลิต (Manufacturing)
- กลุ่มเหยื่อที่เน้นการเรียกไถ่แบบ Double Extortion (ขู่ว่าจะเข้ารหัสและขโมยข้อมูลไปขาย)

ประเภทของหน่วยงานเป้าหมาย:

- กลุ่มอุตสาหกรรมเทคโนโลยีสารสนเทศ (IT)
- กลุ่มบริการที่เกี่ยวข้องกับเทคโนโลยีสารสนเทศ (ITES)



การวิเคราะห์เชิงเทคนิค

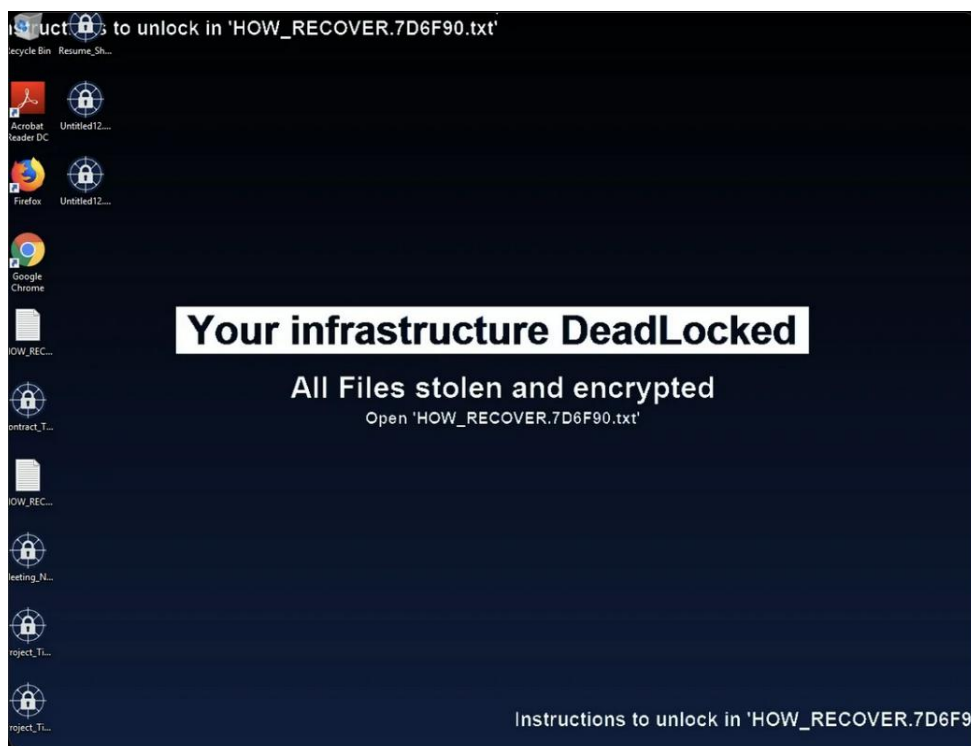
ต้นเหตุการโจมตี

วิธีการเข้าถึงเบื้องต้นของ DeadLock นั้นมีด้วยกันหลายวิธี อ้างอิงจากเหตุการณ์การโจมตีหน่วยงานในไทยพบว่าเป็นการเข้าถึงโดยใช้ข้อมูล Credential ของ VPN และ Root EXSi ของผู้ให้บริการของหน่วยงาน (Outsource) ที่เกิดการรั่วไหล และผู้โจมตีสามารถเข้าถึง ESXi management interface ได้

จากอีกรายงานการโจมตีหนึ่งที่ Cisco Talos สืบสวนได้พบว่า 5 วันก่อนที่จะมีการดีพลอย (deploy) DeadLock ผู้ไม่หวังดีได้ใช้ประโยชน์จากช่องโหว่ CVE-2024-51324 ใน Baidu Antivirus ซึ่งเป็นเทคนิค "bring your own vulnerable driver" (BYOVD) เพื่อยุติ process ของ Endpoint Detection and Response (EDR) ที่ทำงานอยู่บนระบบ

ผลกระทบของการโจมตี

DeadLock เข้ารหัสไฟล์ทั้งหมดและเปลี่ยนนามสกุลไฟล์เป็น .dlock รวมไปถึงค้นหาและยึดไฟล์ข้อมูลสำรองต่าง ๆ และเปลี่ยน icon ของไฟล์, Wallpaper ของเหยื่อเพื่อสั่งให้เปิด Ransom note



[ภาพที่ 1 หน้าจอ Desktop ของเหยื่อหลังถูกโจมตี]



นอกจากการเข้ารหัส ข้อมูลในระบบที่ติดเชื้อมักจะถูกขโมยออกไปด้วย โดย DeadLock ข่มขู่เหยื่อว่าจะขายข้อมูลที่ขโมยมาหากไม่ยอมจ่ายค่าไถ่ โดยระบุในบันทึกว่า " If you want your data fully decrypted and the files we stole removed from our source, you will have to pay a fee."

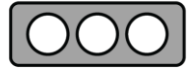
Ransom notes มีการพัฒนาตลอดเวลาจากที่เริ่มแรกเป็นแค่การคุกคามเรื่องการเข้ารหัสธรรมดา มาเป็นการขโมยข้อมูลและการดำเนินการเพิ่มเติม เช่น การให้คำแนะนำด้านความปลอดภัยหรือการรับปากว่าจะไม่ตกเป็นเหยื่อซ้ำ

เป้าหมายของการโจมตี

DeadLock มุ่งเป้าไปยังองค์กรหลายประเภท โดยเบี่ยงเบนจากกลยุทธ์ double extortion แบบปกติ กลุ่มนี้ตั้งเป้าหมายเชิงการเงินเป็นหลัก โดยมีเป้าประสงค์สองด้านคือ

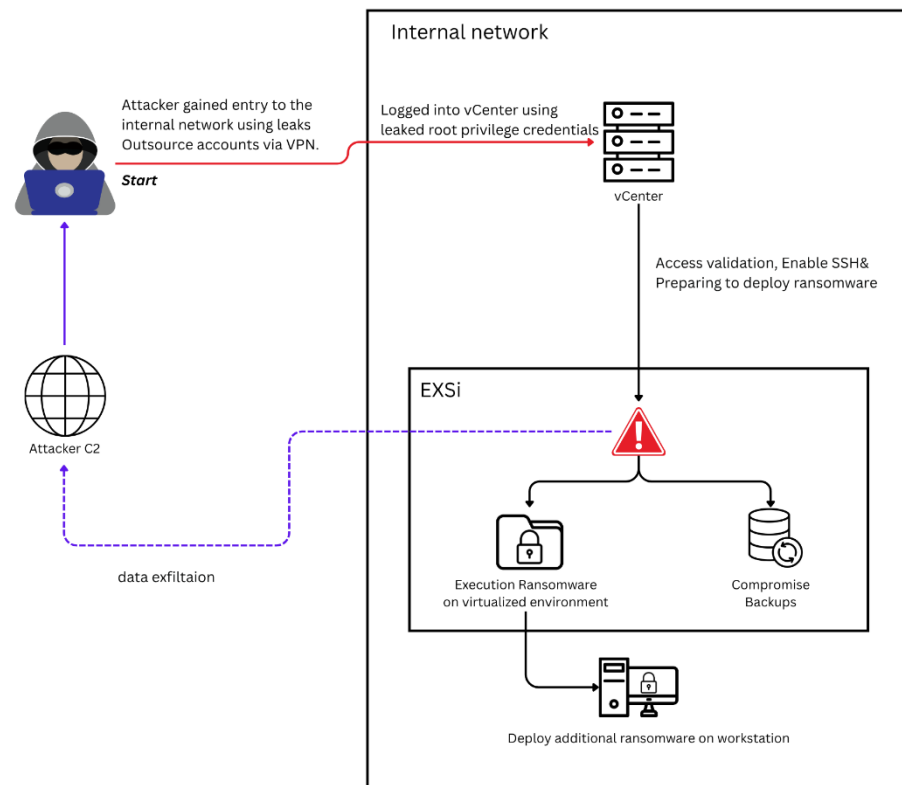
- ค่าไถ่ จากการจ่ายเพื่อถอดรหัสไฟล์
- ขยายข้อมูล ที่ขโมยมาในตลาดมืดหากเหยื่อไม่ยอมจ่าย

กลุ่มนี้พึ่งพาระบบ Messaging ที่เน้นความเป็นส่วนตัวและการเข้ารหัสแบบ end-to-end โดยให้ Session ID แก่เหยื่อแต่ละราย ทำให้ยากที่จะประเมินว่ากลุ่มนี้มีเหยื่อรวมทั้งหมดเท่าไร

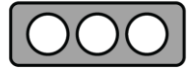


ลำดับขั้นตอนของเหตุการณ์ที่เกิดขึ้นในไทย

1. **Reconnaissance & Initial Access:** ผู้ไม่หวังดีได้ Credential ของ VPN ที่ได้จากการรั่วไหล และใช้ Credential นั้นเข้าถึง Internal network ของหน่วยงานได้
2. **lateral movement & Privilege escalation:** ผู้ไม่หวังดีสามารถเข้าถึง ESXi management interface ได้โดยตรงเนื่องจาก Management IP อยู่ใน Subnet เดียวกับ Production server โดยไม่มี Network segmentation กันและเข้าถึงระบบ vCenter ด้วย Root Credential ที่ได้จากการรั่วไหล เมื่อสามารถเข้าถึงได้ ผู้ไม่หวังดีทำการเปิดใช้งาน SSH เพื่อเตรียมการดีพลอย (deploy) มัลแวร์
3. **Execution:** เมื่อผู้ไม่หวังดีสามารถเข้าถึง vCenter และ ESXi ทั้งหมดได้ ผู้ไม่หวังดีได้ดำเนินการดังนี้
 - 3.1. ขโมยข้อมูลต่าง ๆ และส่งออกกลับไปยัง Command and Control ของผู้ไม่หวังดี
 - 3.2. ค้นหาและยึดข้อมูลสำรองของเหยื่อเพื่อตัดช่องทางการกู้คืนระบบของเหยื่อ
 - 3.3. เรียกใช้งาน Ransomware บน VM ที่สามารถเข้าถึงได้
4. **Additional Execution:** หลังจากที่คุณไม่หวังดีได้ดำเนินการข้างต้นแล้ว ได้มีการดีพลอยและใช้งาน Ransomware เพิ่มเติมอีกบน Workstation

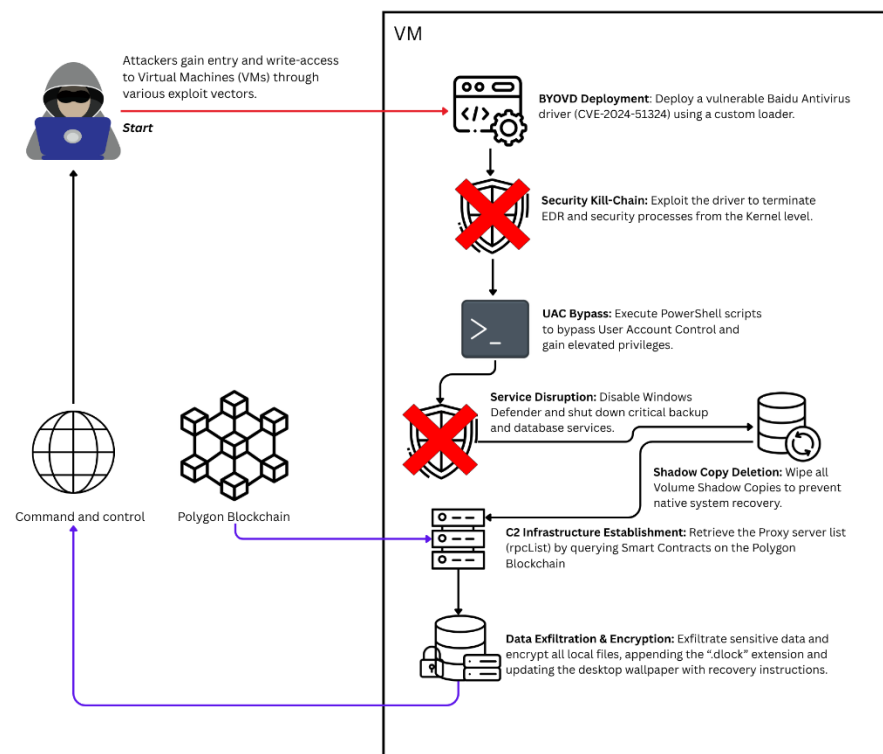


[ภาพที่ 2 แผนภาพการโจมตีเหตุการณ์ในไทย]



ลำดับขั้นตอนของเหตุการณ์อื่น ๆ ที่มีการรายงาน

1. **Initial Access & EDR Suppression:** ผู้โจมตีใช้เทคนิค **Bring Your Own Vulnerable Driver (BYOVD)** โดยอาศัยช่องโหว่ CVE-2024-51324 ใน Baidu Antivirus เพื่อหยุดการทำงานของระบบตรวจจับและตอบโต้ภัยคุกคาม (EDR)
2. **Execution:** เริ่มการทำงานผ่าน Command Line และ PowerShell เพื่อหยุดการทำงานของระบบป้องกัน ดำเนินการลบไฟล์ข้อมูลสำรองต่าง ๆ ยกเว้นระดับสิทธิ์ จากนั้นจึงเรียกใช้ Payload หลัก
3. **C2 Infrastructure Establishment:** มัลแวร์ทำการอ่านข้อมูลจาก Smart Contract บน Polygon (เช่น Address 0xAc9f... และ 0x8ef7...) เพื่อรับรายชื่อ Proxy server (rpcList) ที่จะใช้ในการรับส่งข้อมูล
4. **Data Exfiltration & Encryption:** ทำการขโมยข้อมูลสำคัญและเข้ารหัสไฟล์ทั้งหมดในระบบ โดยเปลี่ยนนามสกุลเป็น .dlock และเปลี่ยน Desktop Wallpaper เพื่อแจ้งวิธีการกู้คืน
5. **Extortion & Negotiation:** บังคับให้เหยื่อติดต่อผ่านช่องทาง Session Messaging ซึ่งเป็นแอปพลิเคชันส่งข้อความแบบเข้ารหัสและกระจายศูนย์ เพื่อความยากในการติดตาม



[ภาพที่ 3 แผนภาพการโจมตีเหตุการณ์ที่เคยมีการรายงาน]



Technique Tactics and Procedures

(MITRE ATT&CK)

MITRE ATT&CK คือฐานความรู้ที่รวบรวมและจัดหมวดหมู่กลยุทธ์และเทคนิคต่างๆ ที่ผู้ไม่หวังดีใช้ในการโจมตีทางไซเบอร์ โดยอ้างอิงจากเหตุการณ์ที่เกิดขึ้นจริง เพื่อให้ฝ่ายป้องกันสามารถเข้าใจและรับมือกับภัยคุกคามได้ดียิ่งขึ้น

Tactic	Technique ID	Technique Name
Initial Access	T1078	Valid Accounts
	T1078.003	Valid Accounts: Local Accounts
	T1133	External Remote Services
Execution	T1059.003	Command and Scripting Interpreter: Windows Command Shell
	T1059.001	Command and Scripting Interpreter: PowerShell
Defense Evasion	T1070.004	Indicator Removal: File Deletion
Impact	T1486	Data Encrypted for Impact



Indicator of Compromise (IOCs)

Indicators of Compromise (IOCs) คือ ร่องรอยหรือหลักฐานทางดิจิทัลที่บ่งชี้ว่าระบบหรือเครือข่ายอาจถูกบุกรุกโดยผู้ไม่หวังดี ซึ่งทาง สกมช. ได้มีการแบ่งปันข้อมูล IOCs เหล่านี้ผ่านทางแพลตฟอร์ม MISP (Malware Information Sharing Platform) เพื่อเสริมสร้างความมั่นคงปลอดภัยไซเบอร์เรียบร้อยแล้ว โดยมีร่องรอยที่สามารถตรวจสอบได้ดังนี้

ร่องรอยที่สามารถตรวจสอบได้:

URL

[http://138.226.236.51/prrq\[.\]php](http://138.226.236.51/prrq[.]php)

[http://94.74.164.207/prrq\[.\]php](http://94.74.164.207/prrq[.]php)

[https://94.74.164.207/prrq\[.\]php](https://94.74.164.207/prrq[.]php)

[https://biggoalsports.co.za/minif\[.\]php](https://biggoalsports.co.za/minif[.]php)

[https://nmsneustadtl.ac.at/xml\[.\]php](https://nmsneustadtl.ac.at/xml[.]php)

[https://envisionreg.com/wp-activate\[.\]php](https://envisionreg.com/wp-activate[.]php)

IP Address

138.226.236[.]51

41.128.145[.]84

94.74.164[.]207

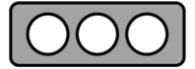
File Hash

3cd5703d285ed2753434f14f8da933010ecfdc1e5009d0e438188aaf85501612

c9cc95ff8f2998229394dfd31c2bd6b723e826a3ca5e008d2b5be19ba419ae2c

3c1b9df801b9abbbb3684670822f367b5b8cda566b749f457821b6481606995b3

be1037fac396cf54fb9e25c48e5b0039b3911bb8426cbf52c9433ba06c0685ce



แนวทางการเฝ้าระวัง ป้องกัน และรับมือ

การเฝ้าระวัง (Monitoring)

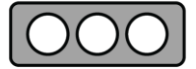
- เฝ้าระวังการเข้าสู่ระบบจากบัญชีที่ถูกต้องแต่อยู่ในช่วงเวลาที่ผิดปกติหรือการเชื่อมต่อไม่ได้มาจาก IP Address ที่เคยเรียกเข้ามาใช้งานปกติ
- ตั้งค่าระบบตรวจจับเครือข่ายเพื่อตรวจสอบการเชื่อมต่อที่ผิดปกติไปยัง Proxy endpoints และการเรียกใช้งาน Web3 JSON-RPC calls ไปยังเครือข่าย Blockchain
- ตรวจสอบพฤติกรรมแปลกๆ ไฟล์จำนวนมากในเวลาอันสั้น โดยเฉพาะการเปลี่ยนนามสกุลเป็น .dlock

การป้องกัน (Prevention)

- จำกัดสิทธิ์การติดตั้ง Driver (Driver Loading Policy) เพื่อป้องกันเทคนิค BYOVD
- ทำระบบ Offline Backup และทดสอบการกู้คืนข้อมูล (Restore Drill) อย่างสม่ำเสมอเพื่อลดผลกระทบหากถูกเข้ารหัสข้อมูล
- ดำเนินการตั้งค่า Whitelist IP สำหรับการเชื่อมต่อ VPN เข้าถึงเครือข่ายภายในองค์กร

การรับมือ (Response)

- ใช้โซลูชัน Advanced EDR ที่สามารถตรวจจับพฤติกรรมแปลกๆ การเปลี่ยนไอคอนไฟล์ และการแก้ไข Registry ของระบบ
- หากตรวจพบการติดเชื้อ ให้ประสานงานทีมที่ปรึกษากฎหมายและผู้เชี่ยวชาญด้าน IR ทันที และควรหลีกเลี่ยงการจ่ายค่าไถ่เพื่อไม่เป็นการสนับสนุนอาชญากร
- แจ้งเหตุการณ์ไปยังหน่วยงานที่เกี่ยวข้องภายในองค์กรและหน่วยงานด้านความมั่นคงปลอดภัยไซเบอร์



อ้างอิง (References)

1. NCSA's Digital Forensic and Incident Response department
2. GroupIB Blog's "DeadLock Ransomware: Smart Contracts for Malicious Purposes"
www.group-ib.com/blog/deadlock-ransomware-polygon-smart-contracts/
3. DeadLock Ransomware
www.broadcom.com/support/security-center/protection-bulletin/deadlock-ransomware
4. SOC Prime "DeadLock: Ransomware Gang Uses Smart Contracts to Mask Its Work"
socprime.com/active-threats/deadlock-ransomware-analysis/
5. Cisco Talos's Blog "New BYOVD loader behind DeadLock ransomware attack"
blog.talosintelligence.com/byovd-loader-deadlock-ransomware/
6. Cyware Daily Threat Briefing "Cyware Daily Threat Intelligence"
www.cyware.com/resources/threat-briefings/daily-threat-briefing/cyware-daily-threat-intelligence-january-15-2026



แบบประเมินรายงานข่าวกรองไซเบอร์

<https://dg.th/nsexlfob51>

จัดทำโดย

ฝ่ายบริหารจัดการข้อมูลภัยคุกคามทางไซเบอร์ สำนักประสานงาน

ศูนย์ประสานการรักษาความมั่นคงปลอดภัยระบบคอมพิวเตอร์แห่งชาติ

โทร: 02 114 3531 อีเมล: cti_misp@ncsa.or.th